

T-DID: Runtime Security Information and Stateful Threat Adjudication for DID/VC Systems

Namryeong Kim, So-Eun Jeon, Seung-Ha Ji, Jin-Min Lee, Il-Gu Lee

Abstract—분산 식별자(Decentralized Identifier, DID)와 검증 가능한 자격증명(Verifiable Credential, VC) 환경에서 특정 위협의 성공 여부를 판정하려면 여러 구성요소에서 수행된 보안 검사와 최종 결과, 사건 간 관계를 함께 확인해야 한다. 그러나 구현체마다 기록되는 정보와 위치가 달라 실행 단위의 판정이 어렵다. 본 연구는 공식 표준, 보안 권고와 구현 자료를 바탕으로 21개 DID/VC 위협을 선정하고, 15개 고정 구현체와 조합한 315개 쌍에서 판정에 필요한 정보의 가용성과 실행 평가 가능성을 분석했다. 그 결과 22개 쌍은 통제된 실행 평가가 가능했고, 142개는 필요한 정보나 결과 확인 경로가 부족했으며, 151개는 위협 조건이 구현체에 적용되지 않았다. T-DID는 위협별 성공 조건을 실행 정보, 정보 생성 구성 요소와 사건 관계에 연결하고, 사건 상태를 이용해 조건 불성립과 정보 부족을 구분한다. OpenID4VCI key-proof replay를 두 발급자에서 평가한 660개 워크플로에서는 정보가 완전한 추가 발급 208개와 정보가 부족한 추가 발급 240개를 구분했으며, 시간적으로 분리한 220개 검증 세트에서도 같은 판정 특성이 유지됐다. 결과는 DID/VC 위협의 실행 성공 여부를 판정하려면 성공 조건뿐 아니라 필요한 정보의 출처, 사건 관계와 정보 부족의 의미까지 함께 정의해야 함을 보여준다.

Index Terms—Decentralized identifiers, distributed systems security, runtime verification, security protocols, verifiable credentials

I. INTRODUCTION

DECENTRALIZED Identifier (DID)와 Verifiable Credential (VC)은 발급자, 소지자와 검증자 사이에서 검증 가능한 신원 정보를 교환하기 위한 기반을 제공한다 [1]. W3C는 DID와 VC의 데이터 모델을, OpenID4VCI와 OpenID4VP는 발급과 제시 절차를 정의한다 [2]–[5]. 실제 발급과 수락 과정에서는 서명 검증 외에도 프로토콜과 정책에 따라 요청 인가, nonce와 응답의 결합, 발급자 신뢰, 자격증명 상태와 키

This work was supported by the Ministry of Trade, Industry and Energy (MOTIE) under the Training Industrial Security Specialist for High-Tech Industry grant [grant number RS-2024-00415520] supervised by the Korea Institute for Advancement of Technology (KIAT); the Ministry of Science and ICT (MSIT) under the ICT Challenge and Advanced Network of HRD (ICAN) program [grant number IITP-2022-RS-2022-00156310]; a National Research Foundation of Korea (NRF) grant [RS-2025-00518150]; and the Information Security Core Technology Development program [grant number RS-2024-00437252] supervised by the Institute of Information & Communication Technology Planning & Evaluation (IITP). (Co-first authors: Namryeong Kim and So-Eun Jeon. Corresponding author: Il-Gu Lee.)

The authors are with the Department of Convergence Security Engineering, Sungshin Women's University, Seoul 16419, South Korea (e-mail: namyoung0718@gmail.com; sjeon@sungshin.ac.kr; shjee2001@gmail.com; jinminlee422@gmail.com; iglee@sungshin.ac.kr).

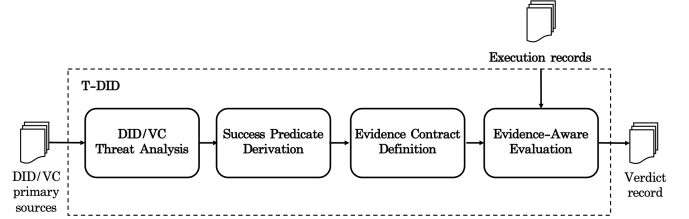


Fig. 1. From DID/VC threat conditions to runtime information requirements and evidence-based verdicts in T-DID.

통제 등이 판정에 관여한다 [3]–[6]. 검사 결과와 최종 결정이 여러 구성요소에 분산되면 최종 결과만으로 위협의 성공 여부를 판단하기 어렵고, 관련 기록을 동일한 실행이나 보안 객체에 연결할 정보가 필요하다.

ATT&CK와 AADAPT는 적대적 행위를, CAPEC는 공격 패턴을, CWE는 구현 약점을 체계화한다 [7]–[10]. 분류체계는 위협의 목적과 행위를 설명하지만, 특정 실행의 성공을 판정하는 데 필요한 값과 정책, 최종 결과까지 규정하지는 않는다. OpenID4VCI의 key-proof replay를 예로 들면, 판정에는 proof 재사용 여부와 검증 결과뿐 아니라 허용 횟수와 추가 발급 결과까지 함께 필요하다 [4]. 21개 위협을 공격 목적, 사전조건, 대상, 작동 방식과 성공 결과로 ATT&CK와 대조한 결과는 Exact 6개, Partial 5개, Analogous 7개, None 3개였으며 세부 근거는 Supplementary Table S2에 제시한다.

판정 조건을 정의해도 필요한 정보가 기본 기록에 남는다는 보장은 없다. CVE-2024-21669가 보고한 ACA-Py의 JSON-LD LDP-VC presentation verification 경로에서는 document.proof 검증 결과가 최종 verified 값에 반영되지 않는 결함이 존재했다 [11], [12]. 최종 결과만 남으면 중간 검사 실패를 확인하기 어렵고, replay 판정에는 서로 다른 요청을 연결하는 상태도 필요하다. OpenTelemetry, OCSF, ECS와 CloudEvents는 공통 로그와 이벤트 구조를 제공하지만, DID/VC 위협별 필수 값과 생산 주체, 사건 관계는 별도로 정의해야 한다 [13]–[16].

T-DID는 위협의 성공 조건을 판정에 필요한 런타임 정보, 생산 주체와 사건 관계로 구체화하고, 구현체 기록을 공통 보안 이벤트와 상태로 연결해 판정한다. 필수 정보가 부족하면 조건 불성립과 구분해 incomplete_evidence로 처리한다. Fig. 1은 위협 조건에서 판정 정보와 T-DID 결과로 이어지는 흐름을 보여준다.

21개 위협과 15개 고정 구현체의 315개 조합에서는 취약점 수나 탐지 성능이 아니라 위협 판정에 필요한 정보의 가용성과 실행 평가 가능성을 분석한다. 주 동적 평가는 OpenID4VCI의 key-proof replay를 대상으로 walt.id와 Credo TS 두 발급자에서 수행하며, 설계한 다섯 판정 조건 중 구현한 세 조건을 평가한다. 별도 통제 사례에서는 두 위협 사례를 이용해 수집 정보에 따른 판정 범위와 구현 간 재사용 가능성을 확인하고, 처리 비용은 실제 제품 서비스와 분리된 단일 프로세스 실험 환경에서 측정한다.

본 연구의 질문은 다음과 같다.

- RQ1.** DID/VC 위협은 기존 분류체계에 어느 범위까지 대응하며, 실행 성공 여부를 판정하려면 어떤 조건을 추가로 정의해야 하는가?
- RQ2.** 위협 판정에 필요한 런타임 정보와 정보 생산 주체 및 사건 관계는 무엇이며, 15개 고정 구현체에서 필요한 정보를 어느 범위까지 확보할 수 있는가?
- RQ3.** 평가 사례에서 기본 기록과 추가 런타임 정보는 어떤 판정을 지원하며, 사건 이력과 정보 부족 처리를 함께 적용했을 때 위협 성립과 판정 불가를 어떻게 구분하는가?
- RQ4.** 평가 대상 통합에서 판정 코드는 어느 범위까지 재사용할 수 있으며, 제안 로깅과 판정 경로의 처리 비용은 연구용 하네스에서 어느 수준으로 나타나는가?

본 논문의 주요 기여는 다음과 같다. 1차 자료를 바탕으로 21개 DID/VC 위협을 다섯 요소로 정의하고, 기존 공격 및 취약점 분류체계와의 대응 관계를 분석한다. 위협별 성공 조건을 런타임 정보, 정보 생산 주체와 사건 관계로 구체화하여 315개 위협-구현체 조합에서 판정 정보의 가용성과 실행 평가 가능성을 체계적으로 분석한다. 또한 공통 보안 이벤트와 상태 기반 판정을 이용해 조건 불성립과 정보 부족을 구분하는 T-DID를 제안하고, 동적 및 통제 평가를 통해 판정 범위, 구현 간 재사용 가능성과 처리 비용을 평가한다.

논문의 구성은 다음과 같다. 제2장은 배경과 관련 연구를, 제3장은 위협과 구현체별 판정 정보를 다룬다. 제4장과 제5장은 T-DID 설계와 구현을 설명하고, 제6장은 평가 결과를 제시한다. 제7장은 논의와 한계를, 제8장은 결론을 정리한다.

II. BACKGROUND AND RELATED WORK

A. DID/VC Security Decisions and Runtime Observability

DID/VC의 발급과 제시 과정에서는 여러 구성요소가 서로 다른 보안 검사를 수행한다. OpenID4VCI 발급자는 자격증명 요청과 key proof를 검증하고, OpenID4VP 검증자는 presentation response가 요청된 nonce와 대상에 부합하는지 확인한다 [4], [5]. VC 검증에서는 적용 정책과 프로파일 따라 발급자 신뢰, 자격증명 상태와 키 통제를 고려하며, DID

resolution은 DID document와 함께 검증 및 해석에 필요한 메타데이터를 반환한다 [2], [3], [6], [17].

표준에 검사 절차가 정의되어 있다는 사실과 특정 실행에서 검사가 수행되어 최종 결정에 반영됐다는 사실은 서로 다르다. 실행 단위 판정에는 검사에 사용된 값, 수행 결과와 최종 발급 또는 수락 결과가 필요하다. nonce, proof, authorization code의 재사용처럼 여러 요청에 걸쳐 성립하는 조건은 이전 실행과 현재 실행을 연결할 상태 정보도 요구한다 [4], [5], [18]. 원문 credential이나 proof 전체를 저장하지 않더라도 동일성 비교와 사건 연결에 필요한 제한된 참조값으로 상태를 유지할 수 있다. 따라서 런타임 보안 판정에서는 프로토콜 메시지 수집 자체보다 검사 결과와 최종 결정, 사건 관계를 함께 확인할 수 있는지가 중요하다.

B. Stateful Runtime Monitoring

런타임 모니터링은 실행 중 관측한 사건을 미리 정의한 명세 또는 보안 속성과 비교해 현재 상태를 판단한다. 명세 기반 모니터링은 사건 순서와 누적 상태를 이용해 단일 사건만으로 결정하기 어려운 속성을 평가하며 [19], Bauer 등은 유한 실행 접두부만으로 만족이나 위반을 확정할 수 없는 경우를 위해 참, 거짓, 미확정의 세 값 의미를 정의했다 [20]. 미확정은 관측 중인 실행이 아직 충분히 진행되지 않은 경우를 나타내며, 판정에 필요한 기록 자체가 존재하지 않는 경우와는 의미가 다르다.

PHOENIX는 셀룰러 제어 트래픽의 사건 순서를 상태 기계 기반 시그니처와 비교해 비정상 동작을 탐지한다 [21]. Farrell 등은 threat model에서 도출한 보안 속성을 형식화하고 정적 검증과 runtime monitor로 연결했으며, Zdun 등은 보안 권고의 준수 여부를 모델 기반 규칙으로 표현해 전문가 판단과 비교했다 [22], [23]. 선행연구는 보안 속성을 실행 가능한 규칙과 상태로 변환하는 방법을 보여주지만, 필요한 관측 정보가 구현체에 존재하지 않을 때의 판정 의미와 정보 생산 위치까지 함께 정의하지는 않는다.

C. Security Event and Provenance Models

여러 구성요소에서 생성된 기록을 함께 분석하려면 필드 의미와 사건 문맥을 정규화할 필요가 있다. OpenTelemetry Logs Data Model은 서로 다른 로그를 공통 레코드로 표현하고, OCSF는 보안 사건을 category와 class로 정규화한다 [13], [14]. ECS는 로그와 trace에 사용하는 공통 필드의 명명 규칙을 제공하며, CloudEvents는 시스템 사이에서 사건 문맥과 데이터를 교환하는 형식을 정의한다 [15], [16]. STIX 2.1은 사이버 위협 객체와 관계를 구조화하고, PROV-DM은 entity, activity와 agent 사이의 출처 관계를, W3C Trace Context는 분산 요청을 동일한 trace로 연결하는 문맥을 정의한다 [24]–[26].

보안 로그의 무결성과 사후 검증 가능성을 보호하는 연구도 존재한다 [27]. 공통 형식과 출처가 확보되더라도 특정

DID/VC 위협을 판정하는 데 필요한 필드는 별도로 정해야 한다. proof replay를 예로 들면 timestamp와 trace identifier만으로는 부족하고, proof 동일성, 검증 결과, 허용 사용 횟수와 실제 발급 결과가 함께 필요하다. T-DID는 범용 로그 형식을 대체하기보다 위협별 판정 정보와 생산 주체를 명시하고, 정보 부족을 조건 불성립과 구분하는 데 초점을 둔다.

D. DID/VC Security Research and Threat Models

DID와 SSI 연구는 구조, 구현, 보안과 개인정보 보호 문제를 폭넓게 다뤘다. Mazzocca 등은 DID/VC의 보안 위협과 완화 방법, 구현 생태계를 종합적으로 분석했고, Fathalla 등은 SSI 구조와 상용 및 연구 시스템을 검토하면서 보안과 운영상 과제를 정리했다 [1], [28]. 두 survey는 DID/VC 보안의 범위와 구현 쟁점을 파악하는 기반을 제공하지만, 개별 실행에서 위협 성공을 판정할 필드와 정보 생산 위치를 정의하는 연구는 아니다.

구체적인 보안 속성을 강화하는 연구도 제안됐다. Huh 등은 DID resolution 과정의 개인정보 노출과 cache 부채널을 분석해 Oblivira를 제안했고, Deng 등은 단일 장애점과 identity revocation 문제를 완화하는 FutureDID를 설계했다 [29], [30]. Hesse 등은 privacy-preserving credential을 실제 소지자와 안전하게 결합하는 방법을 제시했고, Crites 등은 decentralized identity에 적용할 수 있는 Sybil-resilient anonymous signature를 설계했다 [31], [32]. 각각 resolver privacy, 시스템 신뢰 구조, holder binding과 Sybil resilience를 다루지만, 서로 다른 구현에서 위협별 성공 조건을 동일한 런타임 판정 구조로 연결하는 문제와는 범위가 다르다.

W3C의 Decentralized Credentials Threat Model은 credential flow와 trust boundary를 중심으로 보안, 개인정보 보호와 사회기술적 위협을 정리한다 [33]. 현재 문서는 Group Note Draft이므로 규범 표준이 아니라 위협 범위와 신뢰 경계를 확인하는 보조 자료로 사용한다. ATT&CK와 AADAPT는 적대적 행위를, CAPEC는 공격 패턴을, CWE는 구현 약점을 서로 다른 추상화 수준에서 분류한다 [7]–[10]. 공격 행위가 유사하더라도 DID/VC 실행에서는 credential, proof, nonce, session 또는 DID resolution 결과와의 관계가 추가로 필요할 수 있고, 구현 약점의 존재만으로 실제 공격 성공을 확정할 수도 없다.

기존 연구와 표준은 위협 범위, 특정 보안 속성의 보호, 상태 기반 모니터링과 공통 사건 구조를 각각 제공한다. T-DID는 위협별 성공 조건을 런타임 정보, 정보 생산 주체와 사건 관계에 연결하고, 필요한 정보의 확보 여부까지 판정 결과에 반영한다.

III. THREAT ANALYSIS AND RUNTIME SECURITY INFORMATION

본 장은 DID/VC 위협 기준선을 구성하고 기존 보안 분류 체계와의 대응 관계를 분석한다. 이어 위협의 성공 여부를

실행 중 판정하는 데 필요한 런타임 보안 정보, 정보를 신뢰할 수 있게 생성하는 주체와 사건 관계를 도출하고, 15개 고정 버전 구현체에서 정보의 생성 위치와 기본 기록의 확보 범위를 분석한다.

A. Threat Baseline Construction

위협 기준선은 DID 문서와 DID 해석, 자격증명 상태, 발급 및 제시 과정을 대상으로 구성했다 [2]–[6], [33], [34]. DID 해석 관련 근거는 분석 시점을 고정하기 위해 2026년 6월 11일 Working Draft v0.3을 사용했다. 후보 위협은 1차 자료에서 사전조건, 작동 방식과 성공 결과를 구체적으로 정의할 수 있고, 성공 조건을 실행 중 관측할 정보와 그 정보를 생성하는 주체에 연결할 수 있는 경우에 선정했다. DID/VC 절차와 직접 연결되지 않는 일반 플랫폼 문제, 독립된 공격 성공 결과 없이 검사 의무의 누락만을 나타내는 항목, 현재 연구 범위의 실행 정보로 공격 성공을 구분할 수 없는 항목은 제외했다.

초기 후보 31개 중 21개를 선정하고 10개를 제외했으며 보류한 후보는 없었다. 선정 위협에는 TDID-THR-001부터 TDID-THR-021까지 고정 식별자를 부여했다. 식별자는 분석 순서를 나타낼 뿐 심각도, 빈도나 구현체별 보안 수준을 의미하지 않는다. 후보별 선정 및 제외 근거는 Supplementary Table S0에, 최종 21개 위협의 정의와 성공 조건 및 1차 근거는 Supplementary Table S1에 제시한다.

Algorithm 1 Threat and runtime-information analysis.

Require: primary materials P , taxonomies X , fixed implementations I
Ensure: retained threats H , taxonomy map M , runtime-information map R

```

1:  $H \leftarrow \emptyset$ ,  $E \leftarrow \emptyset$ ,  $M \leftarrow \emptyset$ ,  $R \leftarrow \emptyset$ 
2: for each candidate  $c$  derived from  $P$  do
3:    $E[c] \leftarrow \text{EXTRACTFIVEELEMENTS}(c)$ 
4:   if  $c$  is DID/VC-specific and its success condition can be operationalized then
5:      $H \leftarrow H \cup \{c\}$ 
6:   end if
7: end for
8: for each threat  $h \in H$  do
9:    $M[h] \leftarrow \text{RECONCILE}(E[h], X)$ 
10:   $(Q, A, J, S) \leftarrow \text{DERIVERUNTIME REQUIREMENTS}(h)$ 
11:  for each implementation  $i \in I$  do
12:     $R[h, i] \leftarrow \text{INSPECTFIXEDPATH}(i, Q, A, J, S)$ 
13:     $\text{RECORDMISSINGWITHOUTIMPUTATION}(R[h, i])$ 
14:  end for
15: end for
16: return  $H, M, R$ 
```

Algorithm 1은 위협 선정, 분류체계 대조와 구현체별 런타임 정보 분석 절차를 요약한다. 각 위협의 목적, 사전조건, 대상, 작동 방식과 성공 결과를 1차 자료에서 정의한 뒤 기존 분류체계와 대조한다. 성공 조건은 필요한 정보 Q , 정보 생산 주체 A , 사건 관계 J 와 사건 간 상태 S 로 구체화한다. 고정 소스의 처리 경로에서는 정보 생성 위치와 기본 기록 여부를 확인하며, 확인할 수 없는 값은 추정하거나 정상값으로 대체하지 않는다.

TABLE I
CROSS-TAXONOMY MAPPINGS OF THE 21 DID/VC THREATS.

ID	Threat scope	ATT&CK	AADAPT	CAPEC	CWE
THR-001	Pairwise DID linkability	T1589 (A)	ADT3025 (P)	–	CWE-359 (P)
THR-002	Post-compromise key acceptance	T1078 (P)	ADT1552.004 (A)	CAPEC-560 (P)	CWE-672 (P)
THR-003	Post-verification DID substitution	T1565.001 (E)	–	CAPEC-29 (E)	CWE-367 (E)
THR-004	Equivalent-URL cache exhaustion	T1499.003 (E)	ADT3009 (A)	CAPEC-125 (P)	CWE-770 (E)
THR-005	DID URL parameter injection	–	–	CAPEC-137 (E)	CWE-116 (E)
THR-006	Tampered external resource	T1565 (E)	ADT3012.004 (P)	CAPEC-148 (E)	CWE-345 (E)
THR-007	Dereferencing cycle	T1499.004 (P)	ADT3009 (A)	CAPEC-130 (E)	CWE-674 (E)
THR-008	Duplicate-parameter differential	–	–	CAPEC-460 (P)	CWE-436 (E)
THR-009	Cache-bypass denial of service	T1499.003 (E)	ADT3009 (A)	CAPEC-125 (E)	CWE-400 (E)
THR-010	relativeRef path traversal	–	–	CAPEC-139 (E)	CWE-706 (E)
THR-011	Out-of-session status tracking	T1119 (A)	ADT3025 (A)	CAPEC-212 (P)	CWE-359 (E)
THR-012	Issuer status correlation	T1589 (A)	ADT3025 (A)	CAPEC-212 (P)	CWE-359 (E)
THR-013	Active content execution	T1203 (E)	ADT3010 (A)	CAPEC-63 (E)	CWE-79 (E)
THR-014	Stable credential linkability	T1589 (A)	ADT3025 (A)	–	CWE-359 (P)
THR-015	Key-proof replay issuance	T1212 (P)	ADT3012.006 (P)	CAPEC-60 (A)	CWE-294 (E)
THR-016	Split-wallet deputy impersonation	T1550 (P)	ADT3018 (A)	CAPEC-151 (E)	CWE-287 (E)
THR-017	Transaction-code phishing	T1598 (A)	–	CAPEC-98 (E)	CWE-346 (E)
THR-018	Repeated DCQL probing	T1589 (P)	ADT3027 (A)	CAPEC-462 (P)	CWE-203 (E)
THR-019	direct_post session fixation	T1557 (A)	–	CAPEC-61 (E)	CWE-384 (E)
THR-020	Cross-issuer claim collision	T1078 (A)	–	CAPEC-151 (P)	CWE-287 (P)
THR-021	Cross-transaction presentation replay	T1212 (E)	ADT3012.006 (P)	CAPEC-60 (P)	CWE-294 (E)

The fixed TDID- prefix is omitted in the ID column. E: exact; P: partial; A: analogous; –: no corresponding entry identified.

B. Taxonomy Reconciliation

선정한 21개 위협은 공격 목적, 사전조건, 대상, 작동 방식과 성공 결과의 다섯 요소를 기준으로 ATT&CK, AADAPT, CAPEC와 CWE의 관련 항목과 대조했다 [7]–[10]. Exact, Partial, Analogous와 None은 본 연구가 대응 범위를 표현하기 위해 정의한 분석 등급이다. 다섯 요소가 모두 일치하면 Exact로 분류하고, 목적, 작동 방식과 성공 결과는 일치하지만 사전조건이나 대상 범위가 다르면 Partial로 분류했다. 목적 또는 결과 수준의 유사성은 있으나 핵심 사전조건이나 작동 방식이 다르면 Analogous로, 작동 방식과 성공 결과를 직접 연결할 항목을 확인하지 못하면 None으로 분류했다.

공저자들이 수행한 초기 ATT&CK 분석은 각자 분류한 결과를 2주 간격의 회의에서 함께 검토하고 논의하는 방식으로 진행했다. 초기 원장의 872개 행은 DID 환경과 관련된 수 있는 ATT&CK 기법을 전술별 배치 단위로 기록한 탐색 자료이며, 고유 기법 수나 최종 위협 수를 뜻하지 않는다. 최종 21개 위협의 대응은 초기 원장을 단순 집계하지 않고 고정된 다섯 요소 기준으로 다시 판정했으며, 행별 판단 근거를 Supplementary Table S2에 제시한다. 초기 원장과 후속 자동 진단 자료는 동반 워크북에 별도로 보존하며 최종 6/5/7/3 결과의 직접 입력으로 사용하지 않는다.

Table I은 21개 위협의 ATT&CK, AADAPT, CAPEC와 CWE 대응 결과를 요약한다. ATT&CK에서는 Exact 6개, Partial 5개, Analogous 7개, None 3개로 나타났다. 대응 등급은 분류체계의 완성도나 우열을 평가하는 지표가 아니라 각 DID/VC 위협과 관련 항목이 다섯 비교 요소에서 일치하는 범위를 나타낸다.

대응 수준의 차이는 실행 판정에서 추가로 구체화할 정보를 보여준다. TDID-THR-003의 post-verification DID substitution은 ATT&CK T1565.001과 다섯 요소가 일치하지만, 실제 판정에는 검증한 DID 문서와 이후 소비한 문서를 같은 보안 객체로 연결할 정보가 필요하다. TDID-THR-002의 post-compromise key acceptance는 T1078과 작동 방식 및 성공 결과가 일치하지만 권위 있는 침해 신호와 유효 시점을 추가로 요구한다. TDID-THR-001의 pairwise DID linkability는 T1589와 목적 수준에서 유사하지만 명시적인 unlinkability 정책과 교차 문맥의 동일성 비교가 필요하다. TDID-THR-005의 DID URL parameter injection은 ATT&CK에서 같은 작동 방식과 성공 결과를 갖는 항목을 확인하지 못했다.

분류체계마다 추상화 수준이 다르므로 같은 위협의 대응 등급도 달라질 수 있다. TDID-THR-015는 ATT&CK T1212와 AADAPT ADT3012.006에 Partial, CAPEC-60에 Analogous, CWE-294에 Exact로 대응한다. CWE-294는 이전에 전송된 유효 인증 자료가 freshness 또는 일회성 사용 검사의 실패로 다시 수락되는 작동 방식을 다루는 반면, AADAPT와 CAPEC 항목은 각각 블록체인의 거래 서명과 세션 식별자를 전제로 한다. ATT&CK의 다섯 요소별 판단 근거는 Supplementary Table S2에, AADAPT, CAPEC와 CWE의 상세 판단 근거는 동반 워크북의 Other_Taxonomies 시트에 제공한다.

RQ1의 분석 결과, 기존 분류체계는 DID/VC 위협을 알려진 공격 행위와 약점에 연결하는 데 유용하지만 분류 항목만으로 실행 판정 조건을 정할 수는 없었다. Exact에서도 DID/VC 실행에서 비교할 객체와 사건 관계를 별도로 구체화

TABLE II
FIXED IMPLEMENTATION SNAPSHOTS AND ANALYSIS SCOPE.

Implementation	Role(s)	Fixed revision	Scope
walt.id identity [35]	Issuer, verifier, wallet	f5b5995	Static analysis + THR-015 evaluation
ACA-Py [36]	Issuer, holder, verifier, mediator, cloud agent	b5bf838	Static analysis
Universal Resolver [37]	Resolver	844752e	Static analysis
EUDI Verifier Endpoint [38]	Verifier, relying party	v0.11.0	Static analysis
EUDI PID Issuer [39]	Issuer	c14af67	Static analysis
Credo TS [40]	Issuer, holder, verifier, agent, resolver	3c32928	Static; THR-015; controlled THR-019 + app
EUDI Android Wallet Core [41]	Wallet, holder	c67b0eb	Static analysis
Bifold Wallet [42]	Wallet, holder, DIDComm edge	41c2c54	Static analysis
Multipaz Wallet [43]	Wallet, holder, backend	a0d63e6	Static analysis
Hyperledger Indentus Cloud Agent [44]	Issuer, holder, verifier, cloud agent	79ca64e	Static analysis
Veramo [45]	Issuer, holder, verifier, agent	3008904	Static analysis
DIF JavaScript DID Resolver [46]	Resolver library	a36ebdb	Static analysis
SpruceID SSI [47]	Credential, resolver library	8963036	Static analysis
SpruceID OpenID4VP [48]	Verifier, wallet library	e5f29b8	Static analysis
Digital Bazaar vc-js [49]	Credential, presentation library	7ddb985	Static analysis

할 필요가 있었고, Partial과 Analogous에서는 사전조건, 대상 또는 작동 방식의 차이를 추가 런타임 정보로 보완할 필요가 있었다.

C. Runtime Information and Producer Analysis

구현체 분석은 발급자, 지갑, 검증자, 에이전트, DID 해석기와 자격증명 라이브러리의 역할을 포함하도록 공개 소스 15개를 목적 표집하고 각 저장소의 revision을 고정하여 수행했다. 표집은 역할과 처리 경로의 다양성을 확보하기 위한 것이며 DID/VC 생태계의 대표성이나 제품 보안 순위를 주장하지 않는다. Table II은 분석 대상의 역할, 고정 revision과 사용 범위를 정리한다.

Bifold Wallet은 Credo를 사용하고 SpruceID OpenID4VP는 SpruceID SSI와 코드를 공유하므로 서로 독립적인 구현 관측으로 해석하지 않았다. 분석은 위협의 성공 조건을 필요한 런타임 정보로 분해하고, 각 정보를 생성하는 구성요소, 같은 요청이나 객체를 연결하는 관계, 여러 사건에 걸쳐 유지할 상태와 최종 보안 결과를 정리하는 방식으로 수행했다. 고정 소스에서는 관련 값이 생성되는 함수, 반환값과 내부 상태, 기본 기록 여부를 확인했다.

일부 정보를 코드에서 확인하더라도 다른 필수 정보가 외부 구성요소나 실행 상태에서만 생성된다면 판정 정보가 완성된 것으로 보지 않았다. 특정 코드 위치에서 검사가 확인되지 않거나 후보 경로가 존재한다는 사실만으로 공격 성공, 취약점, 탐지 성능이나 구현체의 보안 수준을 판단하지 않았다. 고정 소스의 정보 생성 경로와 통제된 실행 평가 가능성도 별도의 분석 결과로 구분했다.

21개 위협 중 11개는 권위 있는 판정 정보를 단일 운영 주체 내부에서 구성할 수 있었고, 10개는 운영 경계를 넘어 외부 정보 생산자와의 협력이 필요했다(Supplementary Table S1). TDID-THR-015에서는 발급자가 proof 검증과 자격증명 발급 결과를 생성하지만, 동일 proof의 반복 사용 여부를 판정하려면 이전 발급과 현재 발급을 연결한 사용 이력과 발급

결과 비교가 필요하다. TDID-THR-019에서는 검증자 세션, 지갑이 처리한 응답, 응답이 도착한 세션과 최종 접근 결정을 여러 구성요소의 기록으로 연결할 필요가 있다.

같은 보안 의미의 정보도 구현체마다 생성 위치가 달랐다. TDID-THR-015에서 walt.id의 고정 버전은 DefaultCredentialProofVerifier에서 key proof를 검증하고 OpenId4VciProtocolService에서 발급 결과와 세션 상태를 처리한다 [35]. Credo TS의 고정 버전은 OpenId4VcIssuerService 내부의 서로 다른 처리 구간에서 proof 검증, 발급 결과와 세션 상태를 생성한다 [40]. 구현체별 필드명이나 함수 위치를 판정 규칙에 직접 결합하기보다 값의 보안 의미, 생산 주체와 사건 관계를 공통 기준으로 사용하는 이유가 여기에 있다.

21개 위협과 15개 구현체를 결합한 315개 조합에서는 위협의 적용 여부, 필요한 정보가 생성되는 고정 처리 경로, 외부 또는 위임된 생산 주체와 기본 기록의 확보 범위를 확인했다. Supplementary Table S3의 I는 정보가 전혀 없다는 뜻이 아니라, 위협 판정에 필요한 전체 정보가 기본 자료만으로 완성되지 않았음을 나타낸다. 전체 315개 행의 판단 근거와 고정 코드 위치는 동반 워크북의 Implementation_Matrix와 Producer_Locators에 제공한다. 분석 결과는 런타임 정보의 생산 위치와 확보 경계를 설명하기 위한 것으로, 315개 조합의 취약점 수나 공격 성공 또는 탐지 성능을 의미하지 않는다. 통제된 실행 평가 가능성과 사례 선정 결과는 제6장에서 다룬다.

RQ2의 분석 결과, DID/VC 위협의 성공 여부를 판정하려면 개별 검사 결과뿐 아니라 최종 발급, 수락 또는 접근 결과, 값을 생성한 주체, 같은 요청이나 객체를 식별하는 사건 관계와 이전 사건의 상태가 함께 필요했다. 같은 의미의 정보도 구현체마다 생성 위치와 기본 기록 여부가 달랐다. 제4장은 분석 결과를 바탕으로 구현체별 기록을 공통 보안 이벤트로 변환하고 사건 간 상태를 이용해 위협의 성공 조건을 판정하는 T-DID의 구조를 설명한다.

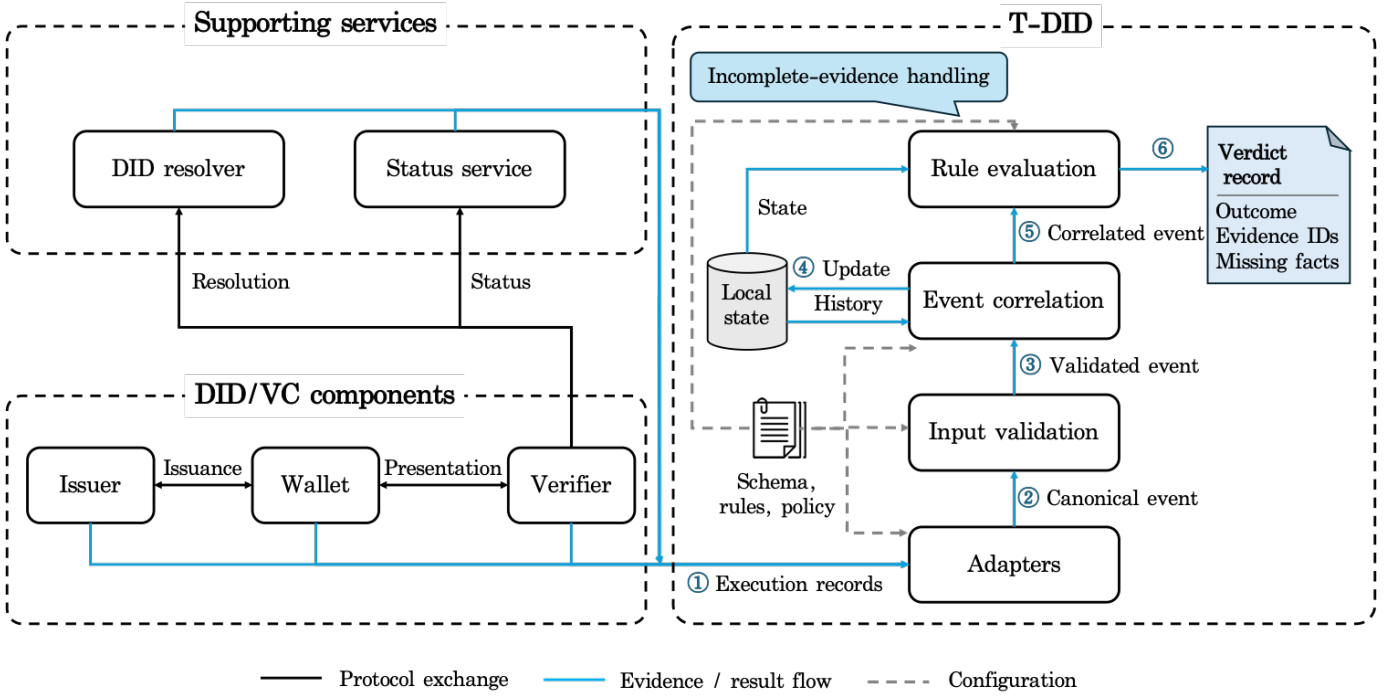


Fig. 2. T-DID runtime evidence flow and verdict generation.

IV. T-DID DESIGN

T-DID는 제3장에서 도출한 위협별 판정 정보를 구현체에 독립적인 공통 보안 이벤트로 정규화하고, 사건 관계와 제한된 상태를 결합해 위협의 성공 조건을 평가한다. 분류체계 식별자는 위협을 기존 보안 지식과 연결하는 메타데이터로만 사용하며 실행 규칙에는 포함하지 않는다. 각 규칙은 DID/VC 1차 자료에서 정의한 성공 조건을 검사 결과, 정보 생산 주체, 사건 관계와 최종 보안 결과에 연결해 구성한다.

A. System Overview

Fig. 2은 DID/VC 구성요소에서 생성된 기록이 T-DID 판정으로 이어지는 흐름을 보여준다. 발급자, 지갑, 검증자와 지원 서비스의 기록은 어댑터에서 공통 필드로 변환되고, 입력 검증과 사건 연결을 거쳐 규칙별 로컬 상태와 함께 평가된다. 번호가 표시된 흐름은 수집, 정규화, 입력 검증, 사건 연결과 상태 갱신, 규칙 평가 및 판정 기록의 순서를 나타낸다. 스키마, 규칙과 정책은 실행 전에 고정되며 분류체계 대응 결과는 실행 입력으로 사용하지 않는다.

어댑터는 원본 기록의 의미를 공통 필드에 대응시키되 원본에 없는 값을 추정하지 않는다. 입력 검증은 스키마 적합성, 정보 생산 주체와 기록 무결성을 확인하고, 사건 연결은 규칙에서 허용한 요청, 객체 또는 제한된 참조값의 범위 안에서만 수행한다. 판정 레코드는 최종 결과뿐 아니라 조건별 결과, 사용한 기록의 참조값과 부족한 정보를 함께 보존한다.

상태 저장소는 전체 이벤트를 하나의 전역 이력으로 합치지 않는다. 각 규칙이 요구하는 범위에 따라 요청, 보안 객체 또는 제한된 참조값을 기준으로 필요한 사건만 연결한다.

단일 운영 주체가 판정 정보를 생성하는 위협은 생산 주체의 로컬 상태에서 처리하고, 여러 구성요소가 필요한 위협은 값의 생산 주체와 허용된 사건 관계를 확인한 뒤 결합한다. 관계를 확인할 수 없는 값은 다른 사건의 값으로 보완하지 않는다.

T-DID는 기존 발급, 제시와 검증 경로 밖에서 동작하며 구현체의 보안 결정을 변경하지 않는다. 식별 가능한 정보 생산 주체와 보호된 수집 경로를 신뢰 범위로 두고, 검증된 입력만 상태와 판정에 사용한다. 로그 관리와 보호된 감사 기록은 수집 및 보관 경로의 신뢰성을 높일 수 있지만, 생산자가 실제 처리와 다른 내용을 기록하거나 사건 자체를 숨기는 경우까지 해결하지는 않는다 [27], [50], [51].

B. Canonical Security Event

공통 보안 이벤트는 구현체별 필드명과 코드 위치를 판정 규칙에서 직접 참조하지 않도록 실행 문맥, 검사 결과, 최종 결정, 사건 연결과 기록 상태를 공통 의미로 표현한다. 전체 필드 구조는 Supplementary Table S8에 제시하며, 본문에서는 판정에 직접 사용되는 필드 그룹만 설명한다.

실행 문맥에는 사건 식별자와 발생 및 관측 시각, 프로토콜, 구성요소 역할, 구현체와 적용 정책을 기록한다. checks는 정책상 필요한 검사, 실제 수행된 검사와 검사별 결과를 분리해 표현하고, final_decision은 발급, 수락 또는 거부와 같은 최종 처리 결과를 별도로 기록한다. 개별 검사의 성공이나 실패가 최종 결정과 동일한 값으로 축약되지 않도록 한 구조다.

사건 연결에는 목적이 제한된 참조값을 사용한다. 예를 들어 `extension.issuance.proof_scoped_ref`는 서로 다른 발급 사건에서 동일한 `proof`를 비교하기 위한 값이고, `event_id`는 하나의 `canonical event`를 식별하기 위한 값이다. 두 필드는 용도가 다르며 서로 대체하지 않는다. 원문 `proof`, `credential` 또는 `access token`은 공통 이벤트에 저장하지 않고, 동일성 비교가 필요한 규칙에서만 운영 범위가 제한된 참조값을 사용한다. 참조값을 생성하지 않은 실행에서는 관련 조건을 추정하지 않고 정보 부족으로 처리한다.

`field_provenance`는 각 값이 기본 기록, 추가 계층, 로컬 계산, 외부 구성요소 또는 정책 중 어디에서 얻어졌는지를 나타낸다. `evidence_integrity_result`는 수집 기록의 무결성 확인 결과를 전달하고, `missing_evidence`는 판정에 필요하지만 확보하지 못한 값과 요구되는 생산 주체를 기록한다. 출처를 확인할 수 없거나 필요한 값이 존재하지 않으면 규칙에서 값을 임의로 보완하지 않는다.

공통 이벤트는 여러 실행에 걸쳐 계산되는 상태를 직접 저장하지 않는다. 반복 횟수, 집합의 크기와 이전 사건과의 관계는 별도의 상태 계약에 따라 관리한다. 상태마다 범위, 입력 전제와 중복 처리 기준이 다르며, `event_id`만으로 모든 상태 갱신의 멍등성을 보장하지 않는다. 예를 들어 동일 `proof`의 수락 횟수는 완전한 `proof` 참조값, 검증 결과, 안정적인 요청 또는 출력 식별자와 실제 발급 커밋이 갖춰진 경우에만 갱신된다. 전체 등록 검사와 열 개의 상태 계약은 Supplementary Tables S9와 S10에 제시한다. 상태 계약의 전제가 부족한 경우 관련 파생 상태를 갱신하지 않는 원칙은 워크북의 `State_Contracts`에도 명시한다.

C. Stateful Verdict Rules

각 판정 규칙은 제3장에서 정의한 위협의 성공 조건을 공통 보안 이벤트와 상태 값에 대응시킨다. 현재 사건에서 확인할 수 있는 조건은 검사 결과와 최종 결정에서 읽고, 재사용 횟수, 사건 순서 또는 이전 처리 결과처럼 여러 실행에 걸친 조건은 상태 저장소에서 계산한다. 규칙은 검사 실패의 존재만 확인하지 않고, 요구된 조건이 추가 발급, 잘못된 수락 또는 접근 승인과 같은 위협의 성공 결과로 이어졌는지까지 평가한다. 21개 위협의 전체 성공 조건과 필요한 정보 생산 주체는 Supplementary Table S5에 제시한다.

Algorithm 2은 공통 이벤트를 이전 상태와 연결하고 판정 결과를 생성하는 절차를 보여준다.

입력의 형식, 정보 생산 주체 또는 무결성을 확인하지 못하면 `input_rejected`를 반환하고 상태를 갱신하지 않는다. 입력 검증을 통과한 경우에도 모든 상태가 자동으로 바뀌지는 않는다. 각 상태 계약이 요구하는 생산자, 사건 관계, 안정적인 중복 제거 식별자와 커밋 조건을 충족한 사실만 상태에 반영한다. 필요한 전제가 빠진 사실은 관련 상태를 변경하지 않으며, `canonical event`에는 정보 부족 상태로 남을 수 있다. 중복 처리도 상태 계약별 식별자를 사용하므로 동일한

Algorithm 2 Stateful threat evaluation in T-DID.

Require: canonical event e , threat rule r , policy π , state S

Ensure: verdict record v

```

1:  $(ok, c, m) \leftarrow \text{VALIDATEINPUT}(e, \pi)$ 
2: if not  $ok$  then
3:    $o \leftarrow \text{input\_rejected}$ 
4: else
5:    $j \leftarrow \text{CORRELATE}(e, S, \pi)$ 
6:   for each state fact  $q$  required by  $r$  do
7:     if  $\text{PREREQUISITESATISFIED}(q, e, j, \pi)$  and not
        $\text{ALREADYAPPLIED}(q, e, S)$  then
8:        $S \leftarrow \text{UPDATESTATE}(S, q, j, e, \pi)$ 
9:     end if
10:  end for
11:   $(s, c, m) \leftarrow \text{EVALUATE}(r, e, S, \pi)$ 
12:  if  $s = \text{ERROR}$  then
13:     $o \leftarrow \text{engine\_error}$ 
14:  else if all success conditions in  $r$  hold then
15:     $o \leftarrow \text{threat\_witness}$ 
16:  else if  $m \neq \emptyset$  then
17:     $o \leftarrow \text{incomplete\_evidence}$ 
18:  else if a policy-required check fails or is not performed then
19:     $o \leftarrow \text{obligation\_violation}$ 
20:  else
21:     $o \leftarrow \text{no\_witness}$ 
22:  end if
23: end if
24:  $v \leftarrow \text{RECORD}(o, c, m, \text{source references}, \pi)$ 
25: return  $v$ 

```

요청의 재시도나 중복 `telemetry`가 새로운 수락 횟수로 계산되지 않는다. 워크북의 `State_Contracts`는 `event_id`만으로 충분하지 않은 상태와 각 멍등성 기준을 구분한다.

위협 성공 조건과 최종 보안 결과가 모두 확인되면 `threat_witness`를 기록한다. 성공 여부나 음성 조건을 판단하는 데 필요한 값이 부족하면 `incomplete_evidence`로 종료한다. 필요한 정보가 갖춰진 상태에서 정책상 필수 검사가 실패하거나 수행되지 않았으나 위협의 성공 결과가 성립하지 않으면 `obligation_violation`, 나머지 조건 불성립은 `no_witness`로 구분한다. 규칙 엔진 자체가 평가를 완료하지 못한 경우는 `engine_error`로 분리한다. 판정 결과의 전체 의미는 Supplementary Table S7에 제시한다.

TDID-THR-015는 여러 발급 사건의 상태가 필요한 대표적인 규칙이다. OpenID4VCI는 획득한 `key proof`가 재사용될 경우 동일한 키에 중복 자격증명이 발급될 수 있음을 설명하고, `proof freshness`를 확인하는 `nonce`를 주요 방어 수단으로 제시한다 [4]. T-DID는 `proof replay`가 실제 중복 발급으로 이어졌는지를 판정하기 위해 동일 `proof`, `proof` 검증, 허용된 사용 횟수, 추가 발급과 최종 발급 결과를 하나의 성공 조건으로 구성한다. 두 발급 사건 e_1 과 e_2 의 `proof`를 p_1, p_2 라고 하면 설계한 조건은 다음과 같다.

$$\begin{aligned}
 W_{15}(e_1, e_2) \iff & \text{SameProof}(p_1, p_2) \\
 & \wedge \text{ProofValid}(p_2) \\
 & \wedge \neg \text{WithinUseLimit}(p_2) \\
 & \wedge \text{ExtraIssued}(e_2) \\
 & \wedge \text{Issued}(e_2).
 \end{aligned} \tag{1}$$

SameProof는 직렬화된 proof 전체에 대한 범위 제한 참조값을 비교하고, ProofValid는 후속 요청의 key-proof 검증 결과를 사용한다. WithinUseLimit은 동일 proof의 수락 이력과 정책에 정의된 허용 횟수를 비교한다. ExtraIssued는 후속 요청으로 이전 결과와 구별되는 자격증명이 생성됐는지를 확인하며, Issued는 최종 처리 결과가 실제 발급이었음을 요구한다.

다섯 조건이 모두 확인돼야 TDID-THR-015의 threat_witness가 성립한다. replay된 proof가 거부된 경우, 하나의 발급 결과를 역등적으로 다시 반환한 경우 또는 정책이 허용한 범위 안의 사용은 성공 조건에 해당하지 않는다. proof 비교값, 검증 결과, 사용 이력 또는 발급 결과가 부족하면 정상으로 간주하지 않고 incomplete_evidence로 남긴다.

여러 정보 생산 주체가 필요한 위협도 같은 절차를 따른다. TDID-THR-019의 direct_post session fixation은 요청 중계 여부, 요청을 시작한 세션과 응답을 완료한 세션의 구분, 세션 연결 검사, 공격자 세션의 결과 사용과 최종 수락 여부를 함께 확인한다. 값이 검증자와 지갑 등 서로 다른 구성요소에서 생성되면 허용된 사건 관계를 확인할 수 있을 때만 하나의 성공 조건으로 결합한다. 제6장은 Credo TS와 통제된 relying application을 이용한 별도 사례에서 판정 범위를 평가한다.

식 (1)은 TDID-THR-015에 대해 설계한 다섯 조건 전체를 나타낸다. 제5장과 제6장의 주 동적 평가는 WithinUseLimit, ExtraIssued와 Issued만 구현하므로 결과를 다섯 조건 전체에 대한 탐지 성능으로 해석하지 않는다. 평가 정책에서 허용 횟수를 1로 고정했기 때문에 WithinUseLimit과 ExtraIssued도 서로 독립적인 시험 조건은 아니다.

V. IMPLEMENTATION

본 장은 제4장의 설계를 실제 프로토타입과 평가용 통합 경로로 구현한 방법을 설명한다. 정적 분석은 15개 고정 구현체를 대상으로 하지만, 동적 연동은 TDID-THR-015의 walt.id와 Credo TS 두 발급자에 한정한다. 별도 통제 사례에서는 TDID-THR-019의 Credo TS와 relying application 연동을 추가한다. 따라서 구현 결과는 15개 구현체 전체의 동적 지원이나 탐지 기능을 의미하지 않는다.

A. Prototype Runtime and Adapters

T-DID 프로토타입은 Python 3.12로 구현했으며 입력 검증, 정책 처리, 상태 관리, 규칙 평가와 판정 기록 생성을 모듈로 분리했다. 공통 보안 이벤트는 Pydantic 모델과 JSON Schema 2020-12 검증을 통과한 뒤 상태 처리와 규칙 평가로 전달된다 [?]. 등록되지 않은 필드와 검사 이름, 잘못된 자료형 및 허용되지 않은 확장 필드는 입력 오류로 처리한다. 형식, 정보 생산 주체 또는 무결성 검증에 실패한 입력은 제4장의 Algorithm 2에 따라 input_rejected로 종료한다.

정책 프로파일은 실행에 필요한 검사와 임계값을 정의하며, 어댑터는 정책에 없는 검사를 추가하거나 관측되지 않은 값을 기본값으로 생성하지 않는다. 판정에 필요한 값이 없으면 누락 상태를 유지한다. 상태 저장소는 제4장의 상태 계약에 정의된 갱신 전제와 상태별 역등성 기준을 따른다. 늦게 도착한 사건도 계약의 시간 범위와 갱신 전제를 충족할 때만 반영하며 이미 생성된 판정 기록을 소급해 바꾸지 않는다. 현재 프로토타입은 사건을 순차 처리하고 상태를 프로세스 메모리에 보관한다.

구현체별 어댑터는 입력 변환을 lift와 enrich 단계로 나눈다. lift는 원본 로그, 함수 반환값과 처리 결과에서 실제로 관측된 값만 읽고, enrich는 적용 정책, 구성요소 역할과 구현체 정보를 결합해 공통 보안 이벤트를 생성한다. 필드의 생성 경로는 Native, Instrumented, Derived, External, Configured, Unavailable로 기록한다. provenance는 신뢰도 등급이 아니라 판정에 사용한 정보의 출처를 추적하기 위한 메타데이터다. 전체 필드, 검사와 상태 계약은 Supplementary Tables S8-S10에 제시한다.

proof, credential과 access token의 원문은 공통 보안 이벤트에 저장하지 않는다. 동일성 비교가 필요한 규칙에서는 정해진 운영 범위에서만 사용할 수 있는 참조값을 생성하고 원문은 이후 단계로 전달하지 않는다. 제4장의 일반 설계는 proof_scoped_ref를 지원하지만, 주 동적 평가의 등록 입력에는 proof 동일성 참조값과 key-proof 검증 결과를 포함하지 않았다. 설계에서 지원하는 필드와 실제 평가 입력의 범위는 구분한다.

B. Integrated Evaluation Paths

TDID-THR-015의 동적 연동은 Table II에 고정한 walt.id와 Credo TS 소스를 사용한다 [35], [40]. walt.id는 발급자 서비스를 HTTP로 실행하고 요청과 응답 경계에서 평가용 발급 결과와 종료 상태를 수집한다. Credo TS는 라이브러리 형태의 발급 경로에 외부 시험용 래퍼를 연결해 같은 의미의 값을 수집한다. 두 경로 모두 제품의 발급 결정을 수정하지 않으며 T-DID 평가는 제품 경로 밖에서 수행한다.

주 동적 평가는 두 발급자에서 동일한 세 조건 평가를 사용하지만 정보 수집 위치는 구현체마다 다르다. 통합 코드가 생성한 값은 Instrumented로 표시해 제품의 기본 기록과 구분한다. 정적 분석에서 확인한 나머지 13개 구현체에는 동적 어댑터나 평가를 구현하지 않았다.

별도 통제 평가에서는 위협별 판정 정보 명세와 공통 판정 코어를 재사용한다. TDID-THR-019에는 Credo TS와 통제된 relying application 사이의 세션 중계와 최종 접근 결과를 연결하는 변환 모듈과 어댑터를 추가했다. 재사용 범위는 판정 의미와 공통 코어에 한정되며 Canonical Event 3.0의 전체 필드, 76개 검사와 10개 상태 계약을 모든 통합에서 실행했다는 의미는 아니다. 평가별 구현 범위와 non-claim은 Supplementary Table S6에 정리한다.

TABLE III
IMPLEMENTED SCOPE FOR TDID-THR-015.

Condition	Implemented evidence	Evaluated
SameProof	Proof equality not collected	No
ProofValid	Key-proof validation result not collected	No
WithinUseLimit	Distinct issuance count vs. allowed count	Yes
ExtraIssued	Additional distinct credential result	Yes
Issued	Issuer terminal issuance result	Yes

C. Implemented Scope of TDID-THR-015

제4장의 식 (1)은 TDID-THR-015의 성공 조건을 SameProof, ProofValid, WithinUseLimit, ExtraIssued와 Issued의 다섯 항목으로 정의한다. 주 동적 평가용 구현은 마지막 세 항목만 계산한다. Table III은 설계 조건과 실제 평가 입력의 차이를 나타낸다.

평가기는 workflow_id와 동일한 발급 권한 범위를 나타내는 authorization_commitment로 관련 발급 사건을 묶는다. 발급 권한 범위는 사건 연결을 위한 키이며 동일한 proof를 의미하지 않는다. 상태에는 같은 범위에서 확인한 서로 다른 credential 결과의 집합과 정책상 허용 횟수를 유지한다. 허용 횟수는 1로 고정하며 동일한 credential 결과의 중복 전달은 새로운 발급으로 세지 않는다. 이전 사건이나 필요한 상태를 확인할 수 없으면 과거 발급을 추정하지 않고 정보 부족으로 처리한다.

WithinUseLimit은 서로 다른 발급 결과 수와 허용 횟수를 비교하고, ExtraIssued는 기존 결과와 구별되는 추가 credential 결과의 존재를 확인한다. Issued는 현재 요청이 실제 발급으로 종료됐는지를 확인한다. 허용 횟수를 1로 고정했으므로 WithinUseLimit과 ExtraIssued는 같은 발급 결과 집합에서 파생되며 서로 독립적인 보안 시험이 아니다.

주 동적 평가 입력에는 직렬화된 proof의 동일성과 key-proof 검증 결과가 없으므로 SameProof와 ProofValid를 판정하지 않는다. 세 평가 항목이 모두 성립해도 식 (1)의 다섯 조건 전체가 입증된 것은 아니다. 제6장은 세 항목이 확인된 결과를 *evaluated-condition witness*로 보고하며 complete five-condition TDID-THR-015 detection 또는 detector accuracy로 해석하지 않는다.

VI. EVALUATION

본 장은 제3장의 정적 분석을 정량적으로 요약하고, 제5장에서 구현한 범위에서 추가 런타임 정보와 사건 이력이 판정 결과에 미치는 영향을 평가한다. 또한 공통 정보 구조가 21개 위협의 판정 요구를 어떻게 수용하는지 확인하고, 제안 로깅과 T-DID 판정의 처리 비용 및 구현 재사용 범위를 측정한다. 315개 조합의 분석, 주 동적 평가, 통제 사례와 부

하 실험은 서로 다른 질문에 답하므로 결과와 분모를 분리해 보고한다.

A. Evaluation Scope and Setup

정적 분석은 21개 위협과 15개 고정 구현체를 조합한 315개 쌍을 대상으로 한다. 각 조합에서는 위협의 성공 조건에 필요한 정보가 기본 기록과 고정 소스의 처리 경로에서 완성되는지, 추가 계측과 독립적인 결과 확인을 포함한 통제 실행 평가를 설계할 수 있는지를 구분했다.

주 동적 평가는 TDID-THR-015의 walt.id와 Credo TS 두 발급자를 대상으로 한다. 제4장의 다섯 설계 조건 중 Table III에 제시한 WithinUseLimit, ExtraIssued, Issued 세 조건만 평가한다. 주 분석은 정상 실행, 정보가 완전한 추가 발급, 정보가 누락된 추가 발급을 포함한 660개 워크플로이며, 시간적으로 분리한 holdout 220개를 별도로 사용한다. 개발에 사용한 44개 워크플로는 두 분모에서 제외한다. 660개와 220개 결과는 두 발급자 경로를 합산해 보고하며 구현체 간 성능 비교에는 사용하지 않는다.

통제 평가는 TDID-THR-015의 두 발급자에서 각각 15개 워크플로, TDID-THR-019의 Credo TS와 통제된 relying application 연동에서 12개 워크플로를 사용한다. 동일한 실행을 대상으로 제품 개발 로그만 사용한 경우와 판정에 필요한 정보를 추가한 경우를 비교한다. 처리 비용은 제품 서비스와 분리된 단일 프로세스 실험 환경에서 측정한다. 평가 범위, 분모와 해석 경계는 Supplementary Table S6에 정리한다.

B. Native Runtime-Information Availability

Fig. 3는 315개 위협-구현체 조합에서 전체 판정 정보가 기본 자료만으로 완성되는지를 나타낸다. 151개 조합은 위협 조건이 구현체의 역할이나 처리 경로에 적용되지 않았다. 적용 가능한 164개 조합은 모두 하나 이상의 필수 정보가 부족했으며, 부족한 항목은 검사 결과, 객체 관계, 사건 이력 또는 최종 보안 결과에 걸쳐 나타났다. 따라서 그림의 진한 셀은 정보가 전혀 없다는 뜻이 아니라 전체 요구사항이 완성되지 않았음을 의미한다.

추가 계측, 결과 확인 절차와 안전한 실행 환경까지 검토한 결과 164개 중 22개 조합은 통제 실행 평가를 설계할 수 있었고 142개는 필요한 정보 또는 독립적인 결과 확인이 부족했다. 22/142/151 구분은 실행 평가의 현재 정보 경계를 나타내며 취약점 수, 공격 성공률이나 탐지 정확도가 아니다. 전체 315개 행의 판정 상태는 Supplementary Table S3과 동반 워크북의 Implementation_Matrix에 제공한다.

C. Dynamic and Controlled Evaluation

주 동적 평가에서 두 발급자의 기본 기록만으로는 허용 횟수 초과, 이전 결과와 구별되는 추가 발급, 최종 발급 결과를 함께 확인할 수 없었다. 기본 기록을 공통 형식으로 변환하는

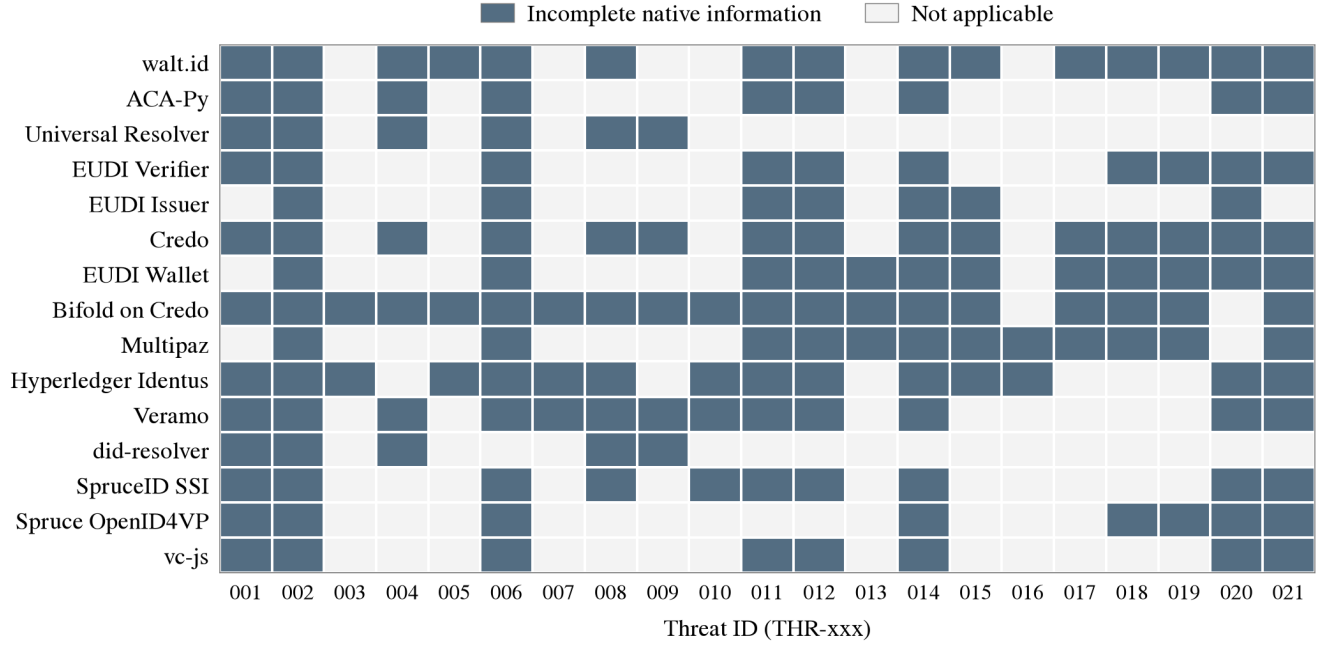


Fig. 3. Native runtime-information completeness across 315 threat-implementation pairs. Cell color reports whether the full native-information requirement is complete; it does not encode how much information is available.

TABLE IV

PRIMARY TDID-THR-015 OUTCOMES FOR THE 660-WORKFLOW MAIN SPLIT. WITNESSES REFER ONLY TO THE THREE EVALUATED CONDITIONS; “NOT IDENTIFIED” IS NOT A BENIGN VERDICT.

Workflow group	n	No-history comparison	T-DID
Benign	212	212 not identified	210 no witness; 2 incomplete
Excess issuance, complete information	208	208 not identified	208 evaluated-condition witness
Excess issuance, missing information	240	240 not identified	240 incomplete evidence

것만으로 누락된 정보가 보완되지는 않았다. 필요한 런타임 정보를 추가한 뒤에는 같은 입력을 사용하는 이력 미사용 비교 방식과 T-DID를 대조했다. 비교 방식은 현재 사건만 처리하므로 이전 발급과 연결한 사용 횟수와 추가 발급 여부를 계산하지 않는다. T-DID는 사건 이력을 유지하고 필수 정보가 부족한 실행을 *incomplete_evidence*로 구분한다. 두 방식은 이력 사용과 정보 부족 처리를 함께 달리하므로 각 기능의 독립적인 효과를 추정하는 *ablation*으로 해석하지 않는다.

Table IV에서 이력 미사용 비교 방식은 허용 범위를 넘는 추가 발급 448개 모두에서 세 평가 조건을 확인하지 못했다. T-DID는 정보가 완전한 208개를 *evaluated-condition witness*, 정보가 부족한 240개를 *incomplete_evidence*로 구분했다. 정상 실행 212개는 210개의 *no_witness*와 2개의 *incomplete_evidence*로 나뉘었다. 시간 *holdout*에서도

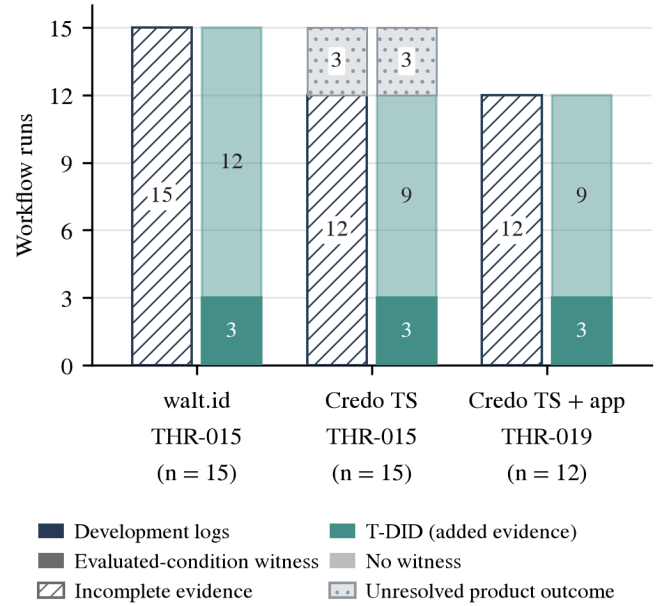


Fig. 4. Controlled evaluation using the same captured executions with development logs or added runtime information. Hatched segments denote incomplete evidence; dotted segments denote unresolved product outcomes.

정보가 완전한 추가 발급 70개와 정보가 부족한 추가 발급 80개는 각각 *evaluated-condition witness*와 *incomplete_evidence*로 분리됐고, 정상 실행 70개에서는 *evaluated-condition witness*가 나타나지 않았다. *holdout*은 동일한 평가 절차와 조건을 시간적으로 분리해 반복한 결과이며 다른 배포 환경에 대한 외적 타당성을 의미하지 않는다.

Fig. 4은 통제 평가에서 동일한 실행의 가용 정보만 바꿔 판정 범위를 비교한다. 개발 로그는 평가 당시 수집한 제품 프로세스의 stdout/stderr이며 제품별 로그 조건과 API 및 source-assisted 비교는 Supplementary Table S6a에 제시한다. walt.id의 TDID-THR-015는 개발 로그만 사용한 15개 실행 모두에서 판정 정보가 부족했지만, 추가 정보에서는 조건 성립 3개와 조건 불성립 12개를 구분했다. Credo TS의 TDID-THR-015는 15개 중 3개의 제품 결과가 독립적인 결과 확인 단계에서 미확정으로 남았고, 나머지 12개는 조건 성립 3개와 조건 불성립 9개로 구분됐다. TDID-THR-019의 12개 실행도 개발 로그만으로는 판정하지 못했지만 추가 정보에서는 조건 성립 3개와 조건 불성립 9개를 구분했다. 제품 결과 미확정은 T-DID의 정보 부족 판정과 별도로 유지한다.

기존 API, callback, SDK와 상태 이벤트를 허용한 Credo TS TDID-THR-015 비교는 추가 정보 조건과 같은 결과를 냈으며, 고정 소스의 제어 흐름까지 허용한 source-assisted 비교는 세 통합 모두에서 같은 판정 범위를 보였다(Supplementary Table S6a). 결과는 특정 표현 형식만이 판정을 가능하게 한다는 주장이 아니라 필요한 정보를 신뢰할 수 있는 경로에서 확보하면 동일한 판정 조건을 평가할 수 있음을 보여준다.

RQ3에 대한 결과는 평가 범위 안에서 사건 이력과 필요한 런타임 정보를 함께 사용할 때 조건 성립, 조건 불성립과 정보 부족을 구분할 수 있다는 것이다. 주 동적 평가는 TDID-THR-015의 다섯 설계 조건 중 세 조건만 다루므로 complete THR-015 detection이나 detector accuracy를 주장하지 않는다.

D. Runtime-Information Requirement Mapping

21개 위협의 판정 요구를 제4장의 공통 이벤트와 생산자 로컬 정보에 다시 대응시킨 결과는 Fig. 5에 제시한다. 매핑은 Supplementary Table S5의 위협별 조건과 Tables S8–S10의 이벤트, 검사 및 상태 계약을 기준으로 수행했다.

실행 문맥은 21개 위협 모두에서 필요했으며 17개는 공통 이벤트 필드로 표현하고 4개는 생산자 로컬 문맥으로 유지했다. 보안 검사와 정책도 21개 전체에서 공통 정보로 사용했다. 최종 결정 또는 보안 효과가 필요한 20개 위협 중 6개는 공통 최종 결정으로 표현할 수 있었고, 14개는 생산자 로컬 결과를 요구했다. 객체 동일성은 21개 전체에서 필요했으며 12개는 공통 참조값, 9개는 생산자 로컬 비교를 사용했다. 사건 연결과 이력도 모든 위협에서 요구됐지만 상태 범위와 갱신 조건은 위협별로 달랐다.

공통 구조로 직접 표현하기 어려운 값은 위협군별 확장으로 분리했다. DID resolution 확장은 4개 위협, issuance, presentation, status 확장은 각각 2개 위협에서 필요했고 privacy와 key lifecycle 관련 값은 각각 1개, pairwise authorization reference는 3개 위협에서 사용됐다. provenance와 정보 완전성은 모든 판정에서 공통 유효성 요건으로 적용됐다. Fig. 5는 요구사항과 정보 구조의 대응 범위를 나타내며 개별 필드의

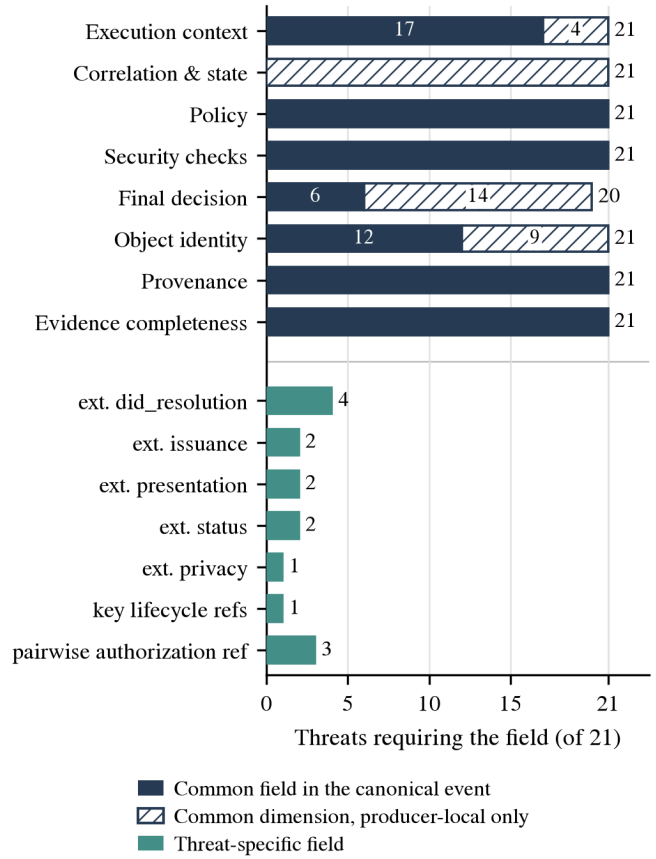


Fig. 5. Mapping of the 21 threat requirements to common event fields, producer-local information, and threat-specific extensions.

최소 필수성이나 field ablation에 따른 탐지 효과를 의미하지 않는다.

E. Processing Cost and Load Response

처리 비용은 제품 실행과 분리된 단일 프로세스 실험 환경에서 evaluator-off 조건과 제안 로깅 및 T-DID 조건을 같은 워크플로 부하로 비교했다. 제공 부하는 초당 1, 2, 4, 6, 8, 9, 10, 11, 12, 13, 14, 16, 18 workflow runs로 구성하고 각 부하와 조건을 10회씩 반복했다. 달성 처리량, 큐 대기기를 포함한 p50 및 p95 지연, 측정 구간 종료 시 backlog와 전체 프로세스 RSS를 기록했다. 포화 지점은 중앙값 달성 처리량이 제공 부하의 95% 미만인 상태가 연속된 두 측정 지점에서 나타날 때 첫 지점으로 정의했다. 집계 규칙과 기록된 실행 환경은 Supplementary Table S6b에 제시한다.

Fig. 6에서 낮은 제공 부하에서는 두 조건 모두 backlog 없이 입력 부하를 처리했다. 등록한 포화 기준은 제안 조건에서 8 runs/s, evaluator-off 조건에서 11 runs/s에 처음 충족됐다. 포화 이후 달성 처리량은 제안 조건에서 약 6–7 runs/s, evaluator-off 조건에서 약 9 runs/s 수준으로 유지됐고, 부하 증가와 함께 지연과 backlog도 증가했다. 전체 프로세스 RSS는 제안 조건에서 고부하 구간 약 190 MiB, evaluator-off 조건에서는 약 65–70 MiB였다.

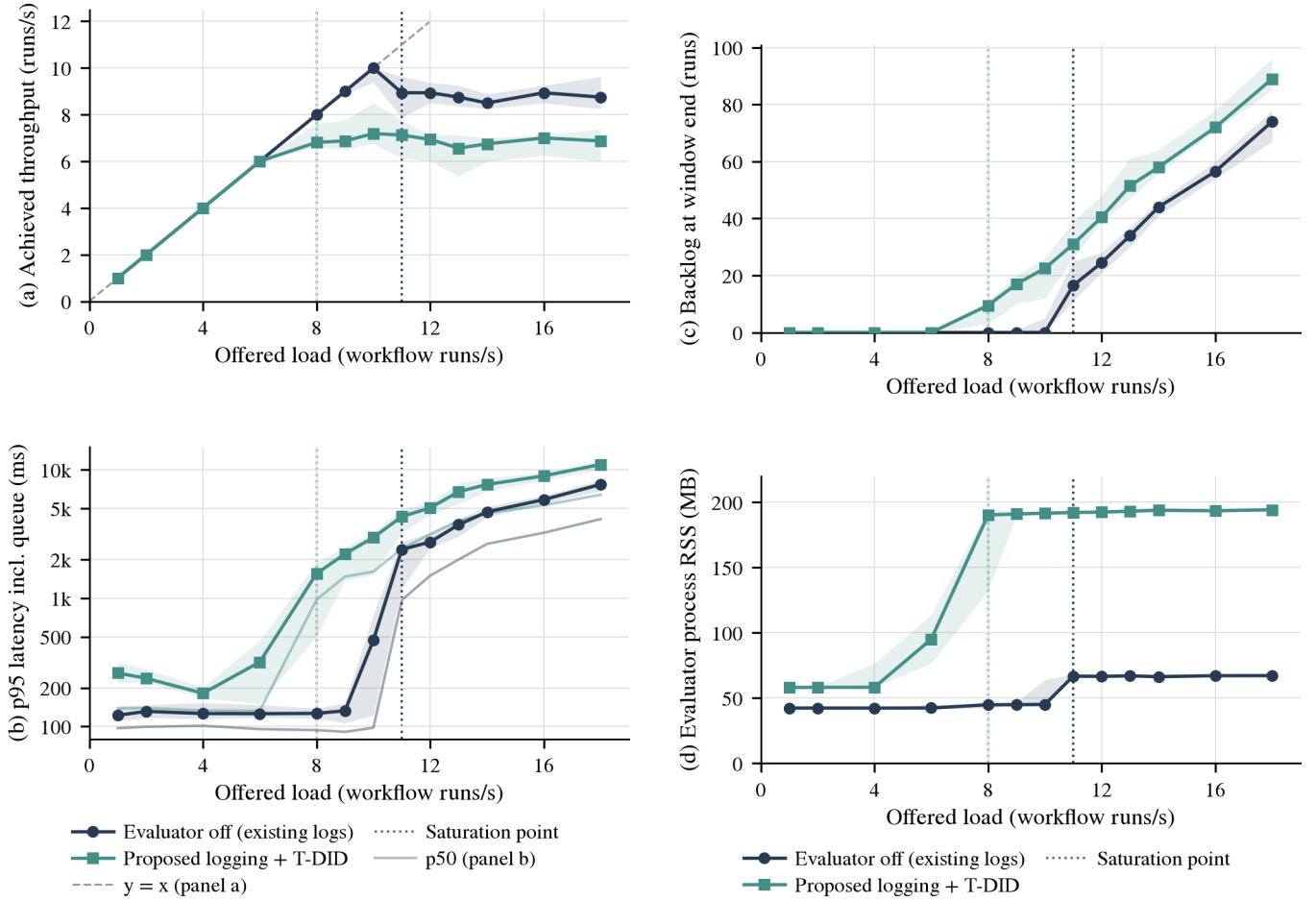


Fig. 6. Load response in the single-process evaluation environment: (a) achieved throughput, (b) latency including queueing, (c) backlog at the measurement-window boundary, and (d) whole-process RSS. Throughput, backlog, and RSS are medians of 10 repetitions; latency is pooled across repetitions. Shading shows observed min-max ranges, not confidence intervals. Dotted lines mark the registered saturation points.

처리량과 메모리 차이는 제안 로그 생성과 판정을 함께 포함한 실험 경로의 비용이다. 개별 로깅 모듈이나 규칙 엔진의 독립 비용, 실제 제품 서비스의 최대 처리량 또는 서비스 수준으로 일반화하지 않는다.

F. Bounded Implementation Reuse

Fig. 7는 통제 평가에 사용한 코드를 공통 부분과 위험 및 제품별 추가 부분으로 나누어 공백을 제외한 줄 수(non-blank LOC)로 나타낸다.

TDID-THR-015의 두 발급자 연동은 50 LOC의 공통 판정 코어와 283 LOC의 평가기 및 어댑터를 공유했다. walt.id에는 77 LOC의 observer/overlay와 제품 내부 연동 20 LOC가 추가되어 총 430 LOC, Credo TS에는 123 LOC의 observer/overlay가 추가되어 총 456 LOC를 사용했다. TDID-THR-019의 Credo TS와 relying application 연동은 50 LOC의 판정 코어를 유지하고, 세션 관계를 처리하는 평가기, reducer 및 어댑터 250 LOC와 제품 및 application 관측 코드 247 LOC를 추가해 총 547 LOC를 사용했다.

공유 범위는 제5장에서 설명한 판정 정보 명세와 공통 판정 로직에 한정된다. TDID-THR-019의 reducer는 THR-019 사건을 처리하는 통제 평가용 배치 로직이며 제4장의 전체 공통 이벤트 스키마와 일반 상태 및 규칙 엔진을 모든 통합에서 사용했다는 의미는 아니다. LOC는 Python, Kotlin과 TypeScript를 함께 쓴 코드 구성 지표이므로 개발 노력, 유지 보수 비용이나 이식 비용의 감소율로 해석하지 않는다.

RQ4의 결과는 같은 위험에서는 공통 판정 코드와 어댑터의 상당 부분을 두 발급자 사이에서 재사용할 수 있었지만, 다른 위험에는 공통 판정 로직 외에 위험별 상태 처리와 관측 코드가 필요했다는 것이다. 처리 비용 실험에서는 제안 로깅과 판정을 추가한 조건이 evaluator-off 조건보다 낮은 부하에서 포화되고 더 많은 프로세스 메모리를 사용했다. 두 결과는 제한된 통제 구현과 단일 프로세스 실험 환경에서 관측한 범위로 한정한다.

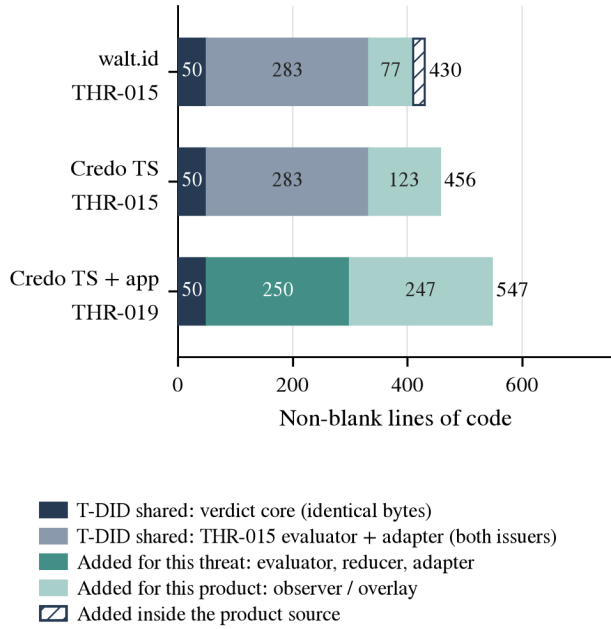


Fig. 7. Non-blank LOC shared or added in the controlled integrations, grouped by common verdict logic, threat-specific evaluation and adaptation, and product-specific observation and integration.

VII. DISCUSSION AND LIMITATIONS

A. Deployment Implications

제6장 결과는 T-DID 적용에서 판정 정보의 생산 위치와 사건 연결 가능성을 먼저 확인해야 함을 보여준다. 기본 개발 로그가 부족했던 사례에서도 기존 API, callback, SDK 또는 추가 계측으로 필요한 값을 확보할 수 있었지만, 소스 분석은 관측 위치를 찾는 근거일 뿐 실제 실행 사실을 대신하지 않는다. 운영 환경에서는 각 값의 생산자와 사건 연결 기준을 위협별로 정해야 한다. 공통 이벤트에는 공유가 필요한 정보만 포함하고 원문 proof, credential과 생산자 내부 상태는 가능한 한 로컬에 유지한다. 장기간 재사용되는 식별자나 참조값은 활동 상관관계에 이용될 수 있으므로 범위, 보관 기간과 접근 권한도 제한할 필요가 있다 [2], [3].

incomplete_evidence는 정보가 부족한 실행을 정상으로 간주하지 않고 추가로 필요한 값과 생산자를 드러낸다. 같은 위협의 판정 코어와 어댑터는 두 발급자에서 공유했지만 관측 위치는 달랐고, 다른 위협에서는 새로운 사건 관계와 관측 코드가 필요했다. 재사용성은 무수정 이식이 아니라 공통 판정 의미와 제품별 관측을 분리하는 범위로 해석한다. 처리 비용도 단일 프로세스 실험 환경에서 제안 로깅과 판정을 함께 측정할 결과로, 특정 제품이나 모듈의 병목을 의미하지 않는다.

B. Limitations and Future Work

15개 구현체는 역할과 처리 경로를 고려해 목적 표집했으며 분석은 고정 revision과 검토 경로에 한정된다. 315개

조합의 분포는 생태계 전체의 취약점 비율이나 제품별 보안 수준을 나타내지 않는다. ATT&CK 872개 초기 분석 행은 공저자 공동 검토를 거친 진단 자료이고, 최종 21개 위협 대응은 별도의 다섯 요소 기준으로 분석했으므로 같은 통계로 해석할 수 없다. 분류 기준과 행별 근거는 보충자료에 공개한다.

주 동적 평가는 THR-015의 두 발급자에서 다섯 설계 조건 중 WithinUseLimit, ExtraIssued, Issued 세 조건만 구현했다. 허용 사용 횟수를 1로 고정했기 때문에 WithinUseLimit과 ExtraIssued는 논리적으로 연동되며, 세 조건을 독립적인 보안 효과로 해석하지 않는다. 별도 THR-015 및 THR-019 통제 사례는 판정 범위를 확인하는 소규모 실험으로 precision이나 recall을 추정하지 않으며, 이력 유지와 정보 부족 처리의 독립적인 효과도 분리하지 않았다.

정보 모델 평가는 위협별 요구사항과 필드의 대응을 분석한 것으로 개별 필드의 최소 필수성을 입증하지 않는다. 처리 비용과 포화점은 단일 프로세스 실험 환경의 결과이며 실제 배포의 최대 처리량으로 일반화할 수 없다. T-DID는 권한 있는 생산자가 실제 처리에 부합하는 기록을 제공하고 수집 및 판정 경로가 보호된다고 가정하며, 허위 기록이나 의도적인 사건 은폐는 자체 검증하지 않는다. 후속 연구에서는 THR-015의 전체 조건과 복수 생산자 위협을 실제 배포 환경에서 평가하고, 이력 유지와 정보 부족 처리의 효과를 분리할 필요가 있다.

VIII. CONCLUSION

본 연구는 DID/VC 위협을 분류하는 것과 특정 실행에서 성공 여부를 판정하는 것이 서로 다른 정보를 요구한다는 점을 바탕으로 21개 위협과 15개 고정 구현체를 분석했다. 315개 위협-구현체 조합 가운데 22개는 통제된 실험 평가를 설계할 수 있었고, 142개는 필요한 정보나 독립적인 결과 확인 절차가 부족했으며, 151개는 위협 조건이 구현체의 역할이나 처리 경로에 적용되지 않았다. T-DID는 위협별 성공 조건을 런타임 정보, 정보 생산 주체와 사건 관계에 연결하고 관련 사건의 상태를 유지해 조건 불성립과 정보 부족을 구분한다.

OpenID4VCI key-proof replay의 두 발급자 평가에서는 다섯 설계 조건 중 세 조건을 구현했다. 660개 워크플로에서 정보가 완전한 추가 발급 208개는 세 평가 조건 성립으로, 정보가 부족한 추가 발급 240개는 정보 부족으로 구분됐고, 별도의 220개 시간 holdout에서도 같은 구분이 재현됐다. 소규모 통제 사례에서는 수집 정보에 따른 판정 범위와 구현 간 재사용 가능성을 확인했으며, 처리 비용은 실제 제품 서비스와 분리된 단일 프로세스 실험 환경에서 측정했다. 결과는 DID/VC 런타임 판정에서 성공 조건, 정보 생산 주체, 사건 관계와 정보 부족의 의미를 함께 정의할 필요가 있음을 보여준다.

REFERENCES

- [1] C. Mazzocca, A. Acar, A. S. Uluagac, R. Montanari, P. Bellavista, and M. Conti, “A Survey on Decentralized Identifiers and Verifiable Credentials,” *IEEE Communications Surveys & Tutorials*, vol. 27, no. 6, pp. 3641–3671, December 2025. [Online]. Available: <https://doi.org/10.1109/COMST.2025.3543197>
- [2] World Wide Web Consortium, “Decentralized Identifiers (DIDs) v1.0: Core Architecture, Data Model, and Representations,” World Wide Web Consortium, W3C Recommendation REC-did-core-20220719, July 2022. [Online]. Available: <https://www.w3.org/TR/2022/REC-did-core-20220719/>
- [3] —, “Verifiable Credentials Data Model v2.0,” World Wide Web Consortium, W3C Recommendation REC-vc-data-model-2.0-20250515, May 2025. [Online]. Available: <https://www.w3.org/TR/2025/REC-vc-data-model-2.0-20250515/>
- [4] OpenID Foundation, “OpenID for Verifiable Credential Issuance 1.0,” OpenID Foundation, Final Specification, September 2025. [Online]. Available: https://openid.net/specs/openid-4-verifiable-credential-issuance-1_0-final.html
- [5] —, “OpenID for Verifiable Presentations 1.0,” OpenID Foundation, Final Specification, July 2025. [Online]. Available: https://openid.net/specs/openid-4-verifiable-presentations-1_0.html
- [6] World Wide Web Consortium, “Bitstring Status List v1.0,” World Wide Web Consortium, W3C Recommendation REC-vc-bitstring-status-list-20250515, May 2025. [Online]. Available: <https://www.w3.org/TR/2025/REC-vc-bitstring-status-list-20250515/>
- [7] MITRE Corporation, “MITRE ATT&CK Enterprise Techniques, Version 19.2,” Data release, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://attack.mitre.org/resources/attack-data-and-tools/>
- [8] —, “MITRE AADAPT: Adversarial Actions in Digital Asset Payment Technologies,” Online knowledge base, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://aadapt.mitre.org/>
- [9] —, “Common Attack Pattern Enumeration and Classification, Version 3.9,” Data release, January 2023, accessed: Aug. 12, 2026. [Online]. Available: <https://capec.mitre.org/data/archive.html>
- [10] —, “Common Weakness Enumeration, Version 4.20,” Data release, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://cwe.mitre.org/data/downloads.html>
- [11] OpenWallet Foundation, “Result of Presentation Verification Not Checked for W3C Format JSON-LD LDP-VC,” GitHub Security Advisory, January 2024, gHSA-97x9-59rv-q5pm; associated with CVE-2024-21669; accessed Aug. 12, 2026. [Online]. Available: <https://github.com/openwallet-foundation/acapy/security/advisories/GHSA-97x9-59rv-q5pm>
- [12] CVE Program, “CVE-2024-21669,” CVE Record, 2024, published Jan. 11, 2024; accessed Aug. 12, 2026. [Online]. Available: <https://www.cve.org/CVERecord?id=CVE-2024-21669>
- [13] OpenTelemetry Authors, “OpenTelemetry Logs Data Model,” Cloud Native Computing Foundation, Specification 1.50.0, October 2025, fixed commit b4bb23c6f2a5e30d3b729cfc425531d4262a6afa. [Online]. Available: <https://github.com/open-telemetry/opentelemetry-specification/blob/v1.50.0/specification/logs/data-model.md>
- [14] Open Cybersecurity Schema Framework, “Open Cybersecurity Schema Framework,” Open Cybersecurity Schema Framework, Schema specification 1.6.0, August 2025, fixed commit d0cd8a0fef198bf93086044e33fda6d80c74b9ef. [Online]. Available: <https://github.com/ocsf/ocsf-schema/tree/1.6.0>
- [15] Elastic, “Elastic Common Schema,” Elastic, Schema specification 9.1.0, August 2025, fixed commit d3d3c52fe57c329f17ea9c619724e55f460d8f6d. [Online]. Available: <https://github.com/elastic/ecs/tree/v9.1.0>
- [16] Cloud Native Computing Foundation, “CloudEvents – Version 1.0.2,” Cloud Native Computing Foundation, Specification 1.0.2, February 2022, version 1.0.2 released February 3, 2022; fixed source snapshot fc1f6f31f5f011a72183f1bcea20c987cb683ade (August 19, 2025). [Online]. Available: <https://github.com/cloudevents/spec/blob/v1.0.2/cloudevents/spec.md>
- [17] World Wide Web Consortium, “Decentralized Identifier Resolution (DID Resolution) v1,” World Wide Web Consortium, W3C Candidate Recommendation Draft CRD-did-resolution-1.0-20260828, August 2026, candidate Recommendation Draft; work in progress. [Online]. Available: <https://www.w3.org/TR/2026/CRD-did-resolution-1.0-20260828/>
- [18] D. Hardt, “The OAuth 2.0 Authorization Framework,” RFC Editor, RFC 6749, October 2012. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6749>
- [19] E. Bartocci, J. Deshmukh, A. Donzé, G. Fainekos, O. Maler, D. Ničković, and S. Sankaranarayanan, “Specification-Based Monitoring of Cyber-Physical Systems: A Survey on Theory, Tools and Applications,” in *Lectures on Runtime Verification*, ser. Lecture Notes in Computer Science. Cham: Springer International Publishing, 2018, vol. 10457, pp. 135–175. [Online]. Available: https://doi.org/10.1007/978-3-319-75632-5_5
- [20] A. Bauer, M. Leucker, and C. Schallhart, “Runtime Verification for LTL and TLTL,” *ACM Transactions on Software Engineering and Methodology*, vol. 20, no. 4, pp. 14:1–14:64, September 2011. [Online]. Available: <https://doi.org/10.1145/2000799.2000800>
- [21] M. Echeverria, Z. Ahmed, B. Wang, M. F. Arif, S. R. Hussain, and O. Chowdhury, “PHOENIX: Device-centric cellular network protocol monitoring using runtime verification,” in *Proceedings of the 2021 Network and Distributed System Security Symposium (NDSS)*, February 2021. [Online]. Available: <https://www.ndss-symposium.org/ndss-paper/phoenix-device-centric-cellular-network-protocol-monitoring-using-runtime-verification/>
- [22] M. Farrell, M. Bradbury, R. C. Cardoso, M. Fisher, L. A. Dennis, C. Dixon, A. T. Sheik, H. Yuan, and C. Maple, “Security-Minded Verification of Cooperative Awareness Messages,” *IEEE Transactions on Dependable and Secure Computing*, vol. 21, no. 4, pp. 4048–4065, July 2024. [Online]. Available: <https://doi.org/10.1109/TDSC.2023.3345543>
- [23] U. Zdun, P.-J. Queval, G. Simhandl, R. Scandariato, S. Chakravarty, M. Jelić, and A. Jovanović, “Detection Strategies for Microservice Security Tactics,” *IEEE Transactions on Dependable and Secure Computing*, vol. 21, no. 3, pp. 1257–1273, May 2024. [Online]. Available: <https://doi.org/10.1109/TDSC.2023.3276487>
- [24] OASIS Cyber Threat Intelligence Technical Committee, “STIX Version 2.1,” OASIS, OASIS Standard, June 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html>
- [25] World Wide Web Consortium, “PROV-DM: The PROV Data Model,” World Wide Web Consortium, W3C Recommendation REC-prov-dm-20130430, April 2013. [Online]. Available: <https://www.w3.org/TR/2013/REC-prov-dm-20130430/>
- [26] —, “Trace Context,” World Wide Web Consortium, W3C Recommendation REC-trace-context-1-20211123, November 2021. [Online]. Available: <https://www.w3.org/TR/2021/REC-trace-context-1-20211123/>
- [27] B. Schneier and J. Kelsey, “Secure Audit Logs to Support Computer Forensics,” *ACM Transactions on Information and System Security*, vol. 2, no. 2, pp. 159–176, May 1999. [Online]. Available: <https://doi.org/10.1145/317087.317089>
- [28] E. Fathalla, M. Azab, C. Xin, and H. Wu, “Self-Sovereign Identity as a Secure and Trustworthy Approach to Digital Identity Management: A Comprehensive Survey,” *ACM Computing Surveys*, vol. 58, no. 7, May 2026, art. no. 190. [Online]. Available: <https://doi.org/10.1145/3785466>
- [29] S. Huh, M. Shim, J. Lee, S. S. Woo, H. Kim, and H. Lee, “DID We Miss Anything?: Towards privacy-preserving decentralized ID architecture,” *IEEE Transactions on Dependable and Secure Computing*, vol. 20, no. 6, pp. 4881–4898, November 2023.

- [30] H. Deng, J. Liang, C. Zhang, X. Liu, L. Zhu, and S. Guo, “FutureDID: A Fully Decentralized Identity System With Multi-Party Verification,” *IEEE Transactions on Computers*, vol. 73, no. 8, pp. 2051–2065, 2024. [Online]. Available: <https://doi.org/10.1109/TC.2024.3398509>
- [31] J. Hesse, N. Singh, and A. Sorniotti, “How to Bind Anonymous Credentials to Humans,” in *32nd USENIX Security Symposium (USENIX Security 23)*. Anaheim, CA, USA: USENIX Association, August 2023, pp. 3047–3064. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity23/presentation/hesse>
- [32] E. Crites, A. Kiayias, M. Kohlweiss, and A. Sarencheh, “Sybil-Resilient Anonymous Signatures with Applications to Decentralized Identity,” in *Proceedings of the 32nd ACM Conference on Computer and Communications Security*. Association for Computing Machinery, 2025, pp. 423–437. [Online]. Available: <https://doi.org/10.1145/3719027.3744806>
- [33] W3C Security Interest Group, “Threat Model for Decentralized Credentials,” World Wide Web Consortium, W3C Group Note Draft DNOTE-threat-model-decentralized-credentials-20260622, June 2026, group Note Draft, June 22, 2026. [Online]. Available: <https://www.w3.org/TR/2026/DNOTE-threat-model-decentralized-credentials-20260622/>
- [34] World Wide Web Consortium, “Decentralized Identifier Resolution (DID Resolution) v0.3,” World Wide Web Consortium, W3C Working Draft WD-did-resolution-20260611, June 2026, analysis snapshot: June 11, 2026; not a W3C Recommendation. [Online]. Available: <https://www.w3.org/TR/2026/WD-did-resolution-20260611/>
- [35] walt.id, “waltid-identity Source Snapshot,” Git repository, commit f5b5995059c4ab69d6bc73f434c72d1574188963, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/walt-id/waltid-identity/tree/f5b5995059c4ab69d6bc73f434c72d1574188963>
- [36] OpenWallet Foundation, “Aries Cloud Agent Python Source Snapshot,” Git repository, commit b5bf8388f80013f2ce3dfdda2a24e200ebd9b717, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/openwallet-foundation/acapy/tree/b5bf8388f80013f2ce3dfdda2a24e200ebd9b717>
- [37] Decentralized Identity Foundation, “Universal Resolver Source Snapshot,” Git repository, commit 844752ee6decc3f23d0aa5e52183d576a19bda69, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/decentralized-identity/universal-resolver/tree/844752ee6decc3f23d0aa5e52183d576a19bda69>
- [38] European Commission, “EUDI Verifier Endpoint v0.11.0 Source Snapshot,” Git repository release v0.11.0, commit 2bc0bd98a81742db321e96d31d88142128006422, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/eu-digital-identity-wallet/eudi-srv-verifier-endpoint/releases/tag/v0.11.0>
- [39] —, “EUDI PID Issuer Source Snapshot,” Git repository, commit c14af675b713acf6a4933fc3d4e169267a77b17c, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/eu-digital-identity-wallet/eudi-srv-pid-issuer/tree/c14af675b713acf6a4933fc3d4e169267a77b17c>
- [40] OpenWallet Foundation, “Credo TypeScript Source Snapshot,” Git repository, commit 3c32928107639bc355f82d4ba11c4d91901e11cb, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/openwallet-foundation/credo-ts/tree/3c32928107639bc355f82d4ba11c4d91901e11cb>
- [41] European Commission, “EUDI Android Wallet Core Source Snapshot,” Git repository, commit c67b0ebbd3c6076b298c372a56d5cc1962658f8, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/eu-digital-identity-wallet/eudi-lib-android-wallet-core/tree/c67b0ebbd3c6076b298c372a56d5cc1962658f8>
- [42] OpenWallet Foundation, “Bifold Wallet Source Snapshot,” Git repository, commit 41c2c54f8bee313e2cc2bfc7d0a35047b2f562e7, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/openwallet-foundation/bifold-wallet/tree/41c2c54f8bee313e2cc2bfc7d0a35047b2f562e7>
- [43] —, “Multipaz Wallet Source Snapshot,” Git repository, commit a0d63e64ed878e1b7a67255617487888e812cf1a, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/openwallet-foundation/multipaz-wallet/tree/a0d63e64ed878e1b7a67255617487888e812cf1a>
- [44] Hyperledger Indentus, “Indentus Cloud Agent Source Snapshot,” Git repository, commit 79ca64e6f0ff42f567d97ed5ee3e3d00efdddbdf9, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/hyperledger-indentus/cloud-agent/tree/79ca64e6f0ff42f567d97ed5ee3e3d00efdddbdf9>
- [45] Decentralized Identity Foundation, “Veramo Source Snapshot,” Git repository, commit 30089045f3fe26c0b00c7f4512e27729941ea643, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/decentralized-identity/veramo/tree/30089045f3fe26c0b00c7f4512e27729941ea643>
- [46] —, “JavaScript DID Resolver Source Snapshot,” Git repository, commit a36ebdb00e5aa5ed7dab53860cfe1c0a79960209, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/decentralized-identity/did-resolver/tree/a36ebdb00e5aa5ed7dab53860cfe1c0a79960209>
- [47] SpruceID, “SpruceID SSI Source Snapshot,” Git repository, commit 89630368438c81b55335362b21621d3aadd48d93, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/spruceid/ssi/tree/89630368438c81b55335362b21621d3aadd48d93>
- [48] —, “SpruceID OpenID4VP Source Snapshot,” Git repository, commit e5f29b85f14ca0b3c6eb6852e4d2d158f601fd63, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/spruceid/openid4vp/tree/e5f29b85f14ca0b3c6eb6852e4d2d158f601fd63>
- [49] Digital Bazaar, “vc-js Source Snapshot,” Git repository, commit 7ddb985a67e42afeb24ef833a5b45ecb72d7771d, 2026, accessed: Aug. 12, 2026. [Online]. Available: <https://github.com/digitalbazaar/vc/tree/7ddb985a67e42afeb24ef833a5b45ecb72d7771d>
- [50] K. Kent and M. Souppaya, “Guide to Computer Security Log Management,” National Institute of Standards and Technology, NIST Special Publication 800-92, September 2006. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-92>
- [51] R. Gerhards, “The Syslog Protocol,” RFC Editor, RFC 5424, March 2009. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc5424>



Namryeong Kim received her B.S. degree in Convergence Security Engineering from SWU in 2023. She is currently pursuing her M.S. degree in Convergence Security Engineering from SWU, where she is also a researcher in the CSE lab. Her current research interests are in the areas of convergence security, blockchains, Web3 security, automated vulnerability detection, AI security.



So-Eun Jeon received her B.S. degree in Convergence Security Engineering from SWU in 2023. She is currently pursuing her M.S. degree in Convergence Security Engineering from SWU, where she is also a researcher in the CSE lab. Her current research interests are in the areas of convergence security, blockchains, Web3 security, automated vulnerability detection, AI security.



Seung-Ha Ji received her B.S. degree in Convergence Security Engineering from SWU in 2023. She is currently pursuing her M.S. degree in Convergence Security Engineering from SWU, where she is also a researcher in the CSE lab. Her current research interests are in the areas of convergence security, blockchains, Web3 security, automated vulnerability detection, AI security.



Jin-Min Lee received her B.S. degree in Convergence Security Engineering from SWU in 2023. She is currently pursuing her M.S. degree in Convergence Security Engineering from SWU, where she is also a researcher in the CSE lab. Her current research interests are in the areas of convergence security, blockchains, Web3 security, automated vulnerability detection, AI security.



Il-Gu Lee received his B.S. degree in Electrical Engineering from Sogang University, Seoul, Korea, in 2003, and his M.S. degree from the Department of Information and Communications Engineering from Korea Advanced Institute of Science and Technology (KAIST), Daejeon, Korea, in 2005. He received his Ph.D. from the Graduate School of Information Security in Computer Science and Engineering Department from KAIST in 2016. He is a Professor at

the Department of Convergence Security Engineering in SWU. Before joining SWU in March 2017, he was with the Electronics and Telecommunications Research Institute (ETRI) as a senior researcher from 2005 to 2017 and had served as a principal architect and project leader for Newratek (KR) and Newracom (US) from 2014 to 2017. His current research interests are in the area of wireless/mobile networks, with an emphasis on information security, computer networks, wireless circuits, and systems. He has authored/co-authored more than 160 technical papers in the areas of information security, wireless networks, and communications, and holds approximately 160 patents. He is also an active contributor to the IEEE 802.11 WLAN standardization committee.